About This Course

ITDS271: Computer and Communication Security

Dolvara Gunatilaka

Instructor Team

Dr. Dolvara GUNATILAKA

Email: dolvara.gun@mahidol.ac.th

1st Part
Lecture 1-5

Dr. Ittipon RASSAMEEROJ

Email: ittipon.ras@mahidol.ac.th

2nd Part
Lecture 6-10

Dr. Assadarat KHURAT

Email: assadarat.khu@mahidol.ac.th

3rd Part
Lecture 11-15

Course Learning Outomes (CLO)

- CLO1: อธิบายหลักการและแนวคิดเกี่ยวกับ Cyber Security พร้อมทั้งมีความเข้าใจในหลักการเรื่องวิทยาการรหัสลับ ความปลอดภัยของแอปพลิเคชัน การรักษาความปลอดภัยฐานข้อมูล และการรักษาความปลอดภัยเครือข่าย
- CLO2: สามารถนำความรู้ที่เรียนไปใช้ในการระบุความเสี่ยง และแก้ปัญหาตัวอย่างด้าน Cyber Security ที่ได้รับมอบหมาย
- CLO3: สามารถประยุกต์ใช้หลักการของความมั่นคงปลอดภัยไซเบอร์ที่ได้เรียนมา เพื่อวิเคราะห์และแก้ปัญหาจากงานที่ได้รับมอบหมายและสามารถให้ข้อเสนอแนะได้อย่างเหมาะสม
- CLO4: มีความตระหนักถึงความรับผิดชอบทางจริยธรรมวิชาชีพทางด้าน Cyber Security

Course Plan and Topics

Mahidol University

Security Concepts and Cryptography

Week 1-5

- Security concpts and priciples
- Security awareness
- Basic cryptography:
  - Symmetric Encryption
  - Asymmetric Encryption
  - Hash Functions

Cybersecurity Applications

Week 6-15

- OS security
- Software security
- Web security
- Network security
- Email security
- Identification/Authentication
- Malware

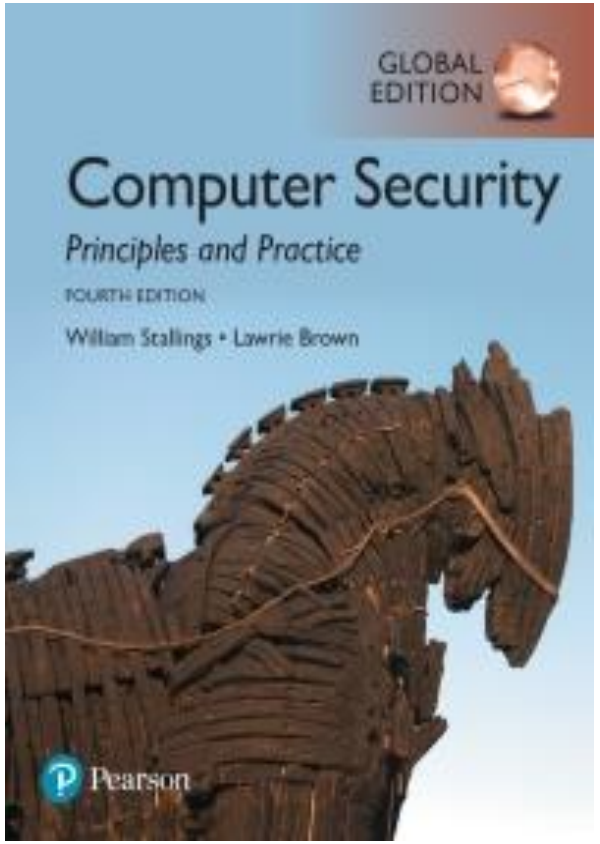
Course Evaluation

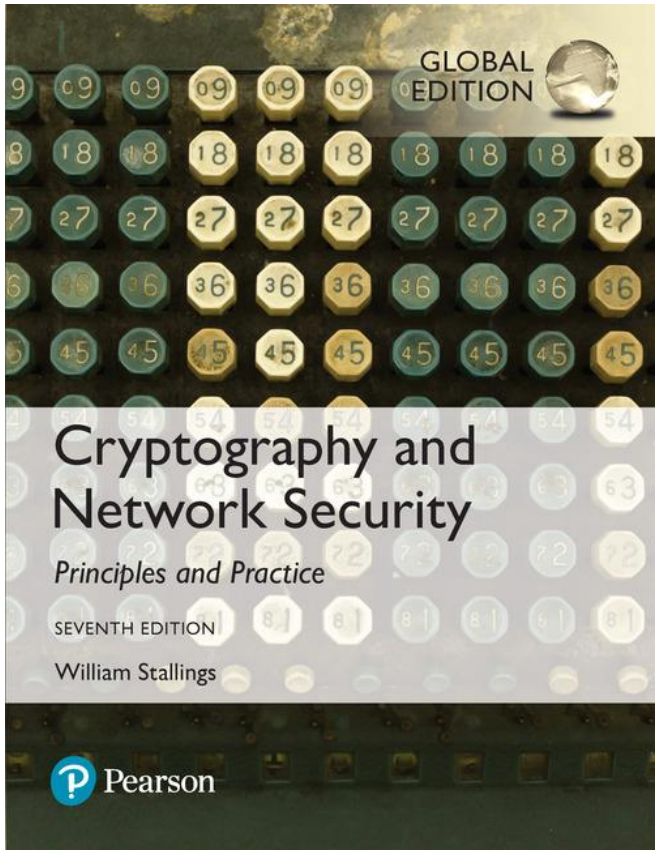
• Quiz (3)	15%
• Assignment	15%
• Midterm Exam	35%
• Final Exam	35%
Total:	**100%**

Course Outline and Textbooks

- Updated course outline will be posted on **MyCourses**
  - be sure to check it out from time to time

- **2 textbooks** are used and recommended for further study about the topics





Sick Leave and Business Leave

- ***Need to submit a leave form + evidence***
- **Sick leave** requires medical certificate (must be submitted within one week)
- **Business leave** considers only business related to the Faculty and university (must be submitted before the absent class)

Lecture 1: Security Overview

ITCS312: Computer and Communication Security

Dolvara Gunatilaka, PhD.

Today's Topics

- **Cybersecurity trends**
- Security definition and terminologies
- Computer security and the CIA triad
- Security attacks
- Security controls
- Social engineering

Cybersecurity Trends: Some Statistics …

- **Global Cost of Cybercrime:** projected to reach **$10.5 trillion annually by 2025**. [Source: Cybersecurity Ventures, BD Emerson, DeepStrike]

- **Frequency of Cyber Attacks:**
  - Cyberattacks occur at a rate of **over 2,200 times daily**, with someone falling victim approximately **every 39 seconds**. [Source: University of Maryland, Embroker]
  - Organizations experienced an average of 1,636 cyberattacks per week in Q2 2024, [Source: Check Point Research]

- **Data Breach:**
  - **83% of organizations** have experienced more than one data breach [Source: IBM Security]
  - Average time to identify and contain a data breach: **277 days**. [Source: SentinelOne]

This clear and accelerating danger, making cybersecurity vital for everyone!

Why Cybersecurity is More Critical Than Ever

- **Financial Impact:** Direct costs from data breaches, ransom payments, recovery efforts, and legal fees can be devastating
- **Reputational Damage:** Loss of customer trust, negative publicity, and harm to brand image can have long-lasting effects
- **Operational Disruption:** Attacks can halt business operations, supply chains, and critical services, leading to significant downtime and economic losses
- **Regulatory Compliance:** Stricter data protection laws (e.g., GDPR/PDPA) impose severe penalties for non-compliance and breaches
- **Personal Privacy:** Individuals face risks of identity theft, financial fraud, and privacy violations

Jobs in Cybersecurity

***Blue Team**: Defensive Security*

- Manage everyday security operation
- Detection, prevention, and response

- Cybersecurity engineer
- IT auditor
- SOC analyst (Tier 1, 2, 3)
- Incident responder
- Digital forensic analyst

***Red Team**: Offensive Security*

- Simulate real-world attacks
- Identify vulnerabilities

- Penetration tester / Ethical hacker

- Malware analyst
- Threat researcher

Today's Topics

- Cybersecurity trends
- **Security definition and terminologies**
- Computer security and the CIA triad
- Security attacks
- Security controls
- Social engineering

Security Definition

- The protection of valuable items called **"assets"** from harm, theft, and unauthorized use

Security in Life

No one should be able to:

- Break into my house
- Harm me or my properties
- Steal my stuffs
- Use my properties without permissions
- ...

Security in CyberLife

No one should be able to:

- Break into my computer
- Attack my computer or damage my computer data
- Steal my information
- Use my resources without my permission
- ...

Security Terminologies

- Resources/Assets
- Vulnerability
- Threats
- Attacks
- Controls
- Risks

Terminologies: Assets and Vulnerability

- **Resources/Asstes:** what we are protecting
  - Can be tangible or non-tangible, e.g., hardware, software, data, infrastructure, people, etc.
- **Vulnerability:** weakness or flaws
  - Holes or gaps in security
  - Can exist in hardware, software, network configurations, human processes, or policies
  - E.g., coding errors, misconfigurations, weak password
  - 3 categories of vulnerability: the resources can be
    - Corrupted → loss of integrity
    - Leaky → loss of confidentiality
    - Unavailable → loss of availability

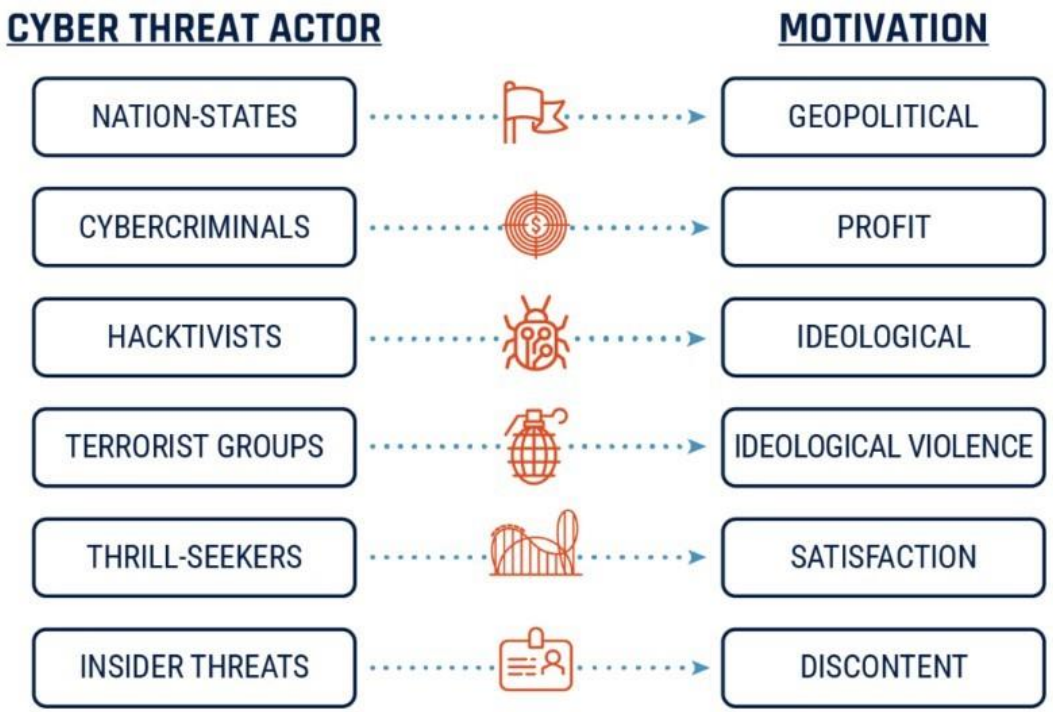
Terminologies: Threats

- **Threats:** harmful events that may cause loss/harm to the assets
  - Something that *could* exploit a **vulnerability**
  - E.g., a natural disaster that could disrupt data center, a new ransomware spreading across the internet
- Categories of threats:
  - **Human-Made Threats:**
    - **Accidental/Negligent:** Employee mistakes, misconfigurations, data entry errors
    - **Malicious:** Cybercriminals, hackers, nation-state actors, disgruntled employees (e.g., malware, phishing, denial-of-service attacks).
  - **Natural Threats:**
    - Floods, earthquakes, fires, power outages, severe weather.

Terminologies: Threat Agent

Threat Agent is an individual, a group, an organization that can initiate a threat, and want to exploit the assets of an organization

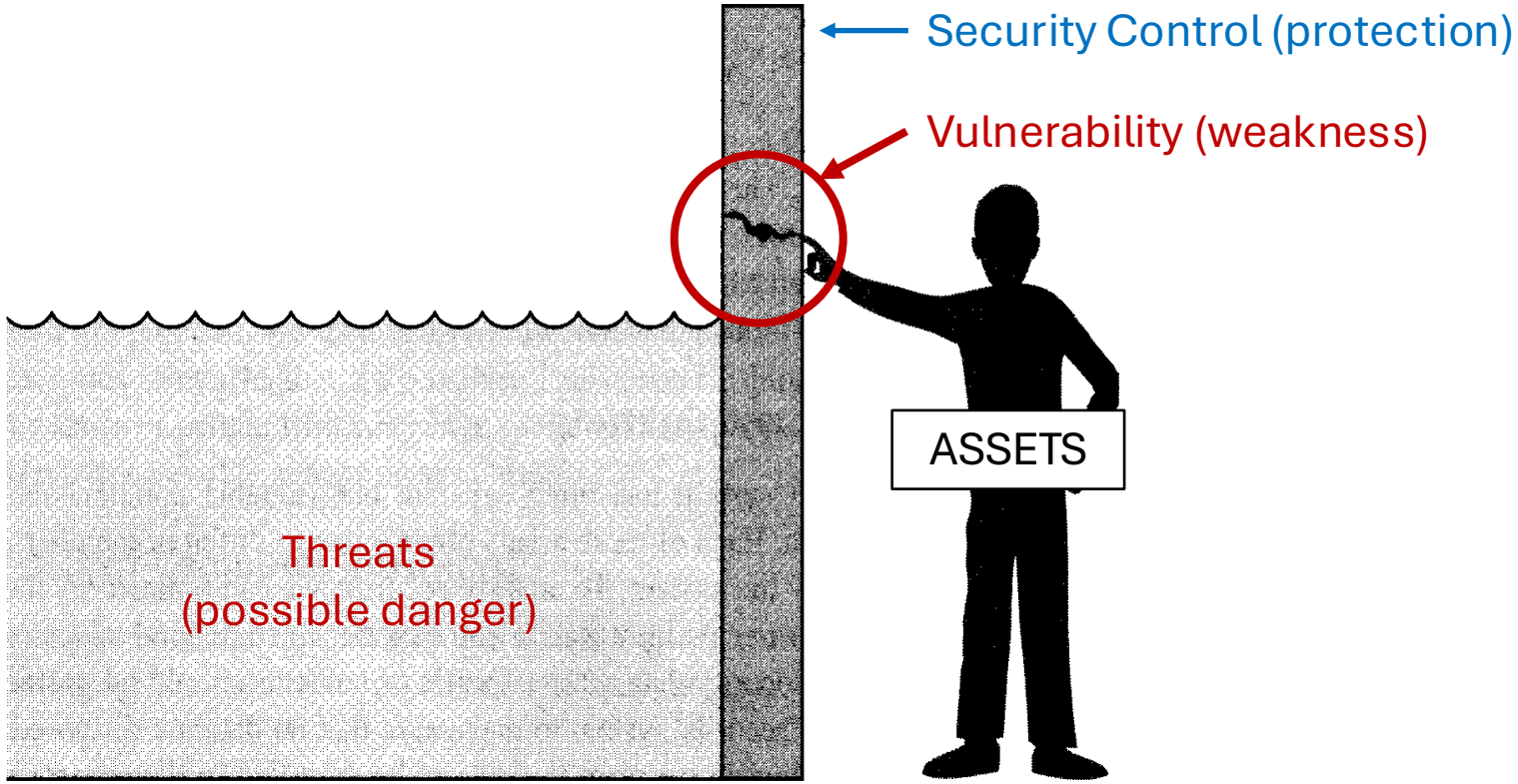
Potential **risk** posed by threat actor = ***capabilities + intention + past activities***



Terminologies: Attacks and Controls

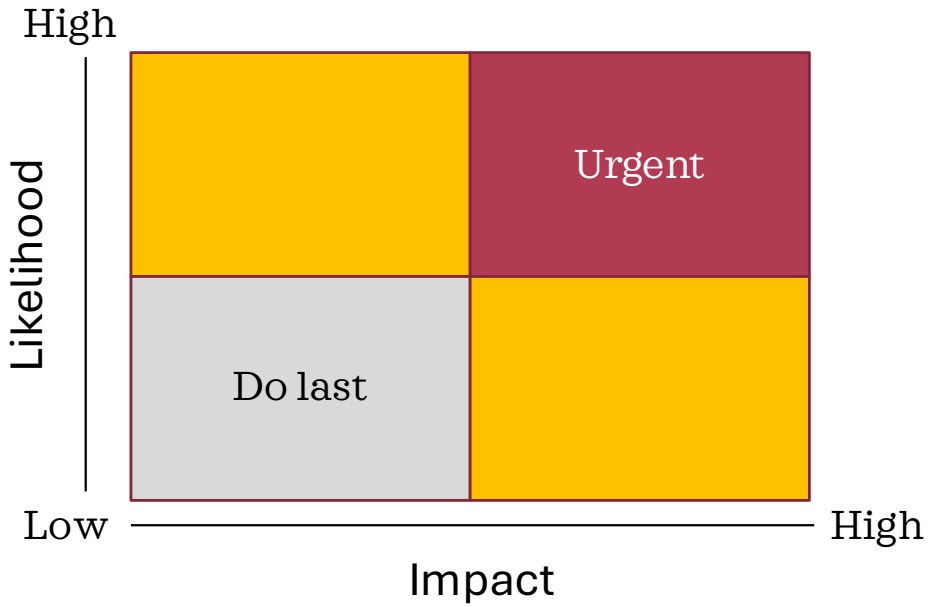
- **Attacks:** actual act of a **threat** exploiting a **vulnerability** to cause harm to an asset
  - Attack is a *deliberate* attempt to evade security services and violate security policy
  - Active adversary
  - E.g., malware attack, brute-force attack, DoS (Denial of Service)
- **Controls**: measures implmented to mitigate or remove the likelihood or impact of vulnerabilities, block threats
  - Can be actions, devices, procedures, or techniques
  - E.g., CCTV, firewall, data backups
- **Should we employ all and every possible security control to the system?**
  - No! That's not possible → **Why?**

Terminologies: Threats, Control, Vulnerabilities



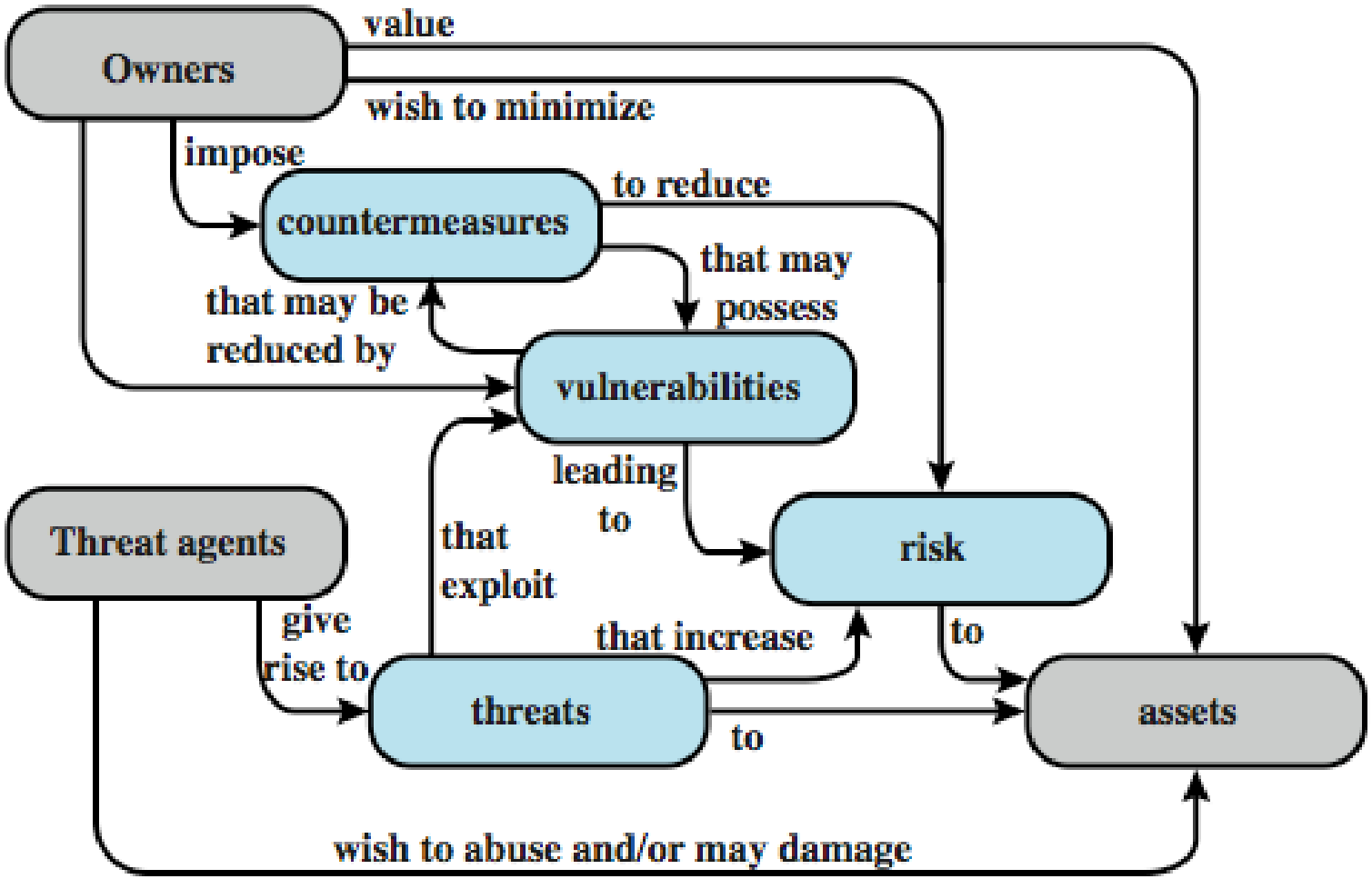
Terminologies: Risks

- **Risk:** The ***probability*** of loss and demage to an asset resulting from a <u>threat</u> *exploiting* <u>vulnerability</u>
  - Expressed as a combination of the ***likelihood*** of an event occurring and the ***impact*** of the event
- **Risk management:** the process to mitigate risks to acceptable level
  - Identify risks
  - Assess and prioritize risks
  - Treat risks
  - Monitor and review risks



Risk treatment:
- Avoid (Eliminate)
- Mitigate (Reduce)
- Transfer
- Accept

Security Concept and Relationship



Q&A

An outdated software system contains a buffer overflow flaw that can be exploited by malicious actors.

What is this an example of?

A. Threat

B. Control

C. Attack

D. Vulnerability

Today's Topics

- Cybersecurity trends
- Security definition and terminologies
- **Computer security and the CIA triad**
- Security attacks
- Security controls
- Social engineering

Compter Security / Cybersecurity

Computer Security

the protection afforded to an automated <u>information system</u> in order to attain the applicable objectives of preserving: Integrity, Availability, and Confidentiality

of information system resources; hardware, software, firmware, information/data, and telecommunications [NIST 800-12]

A more modern term: **Cybersecurity**

Preservation of confidentiality, integrity and availability of information in the Cyberspace [ISO/IEC 27032]

CIA Triad Overview

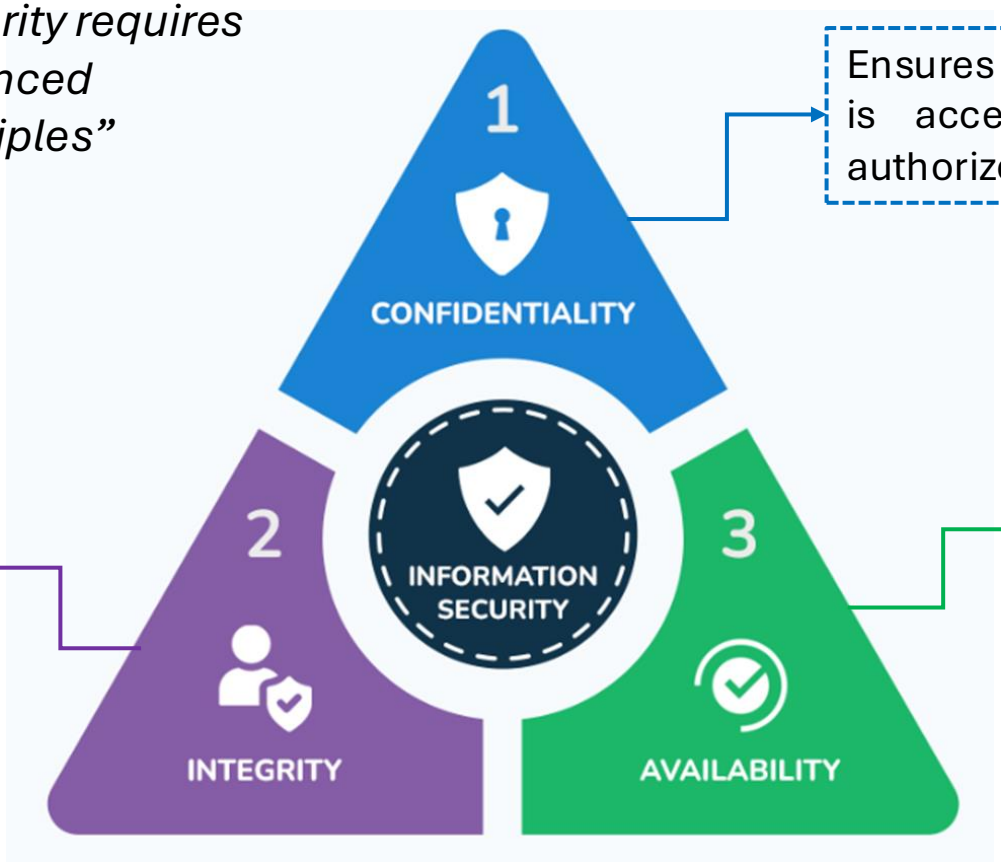
"Effective information security requires a comprehensive and balanced approach to all these principles"

C

Ensures that information is accessible only to authorized individuals.

I

Guarantees that information is accurate, complete, and has not been tampered with by unauthorized means



A

Ensures that authorized users can access the information and systems when needed.

Image: https://www.stationx.net/what-is-the-cia-triad/

CIA Triad: "C"

- Ensures that **data** is **accessible** <u>only</u> to **authorized** individuals
- Prevents sensitive data from being disclosed to unintended parties.
- ***Need-to-Know Principle*** **for Data Access:**
  - *"Only individuals whose job **requires** access to specific information should be granted access to that information"*
  - **Access Control:** Authentication and authorization

✅ **Examples of confidentiality measures:**

- Encryption
- Access control
- Physical security
- …

CIA Triad: "I"

- ***Data Integrity:*** ensures that information has not been **modified** or tampered in an unauthorized manner
  - Guarantees the trustworthiness and reliability of data
  - Key aspects:
    - Accuracy: data is correct and free from errors
    - Completeness: all necessary data is presented
- ***System Integrity:*** assure that a system work as intended and free from unauthorized manipulation

✅ **Examples of integrity measures:**

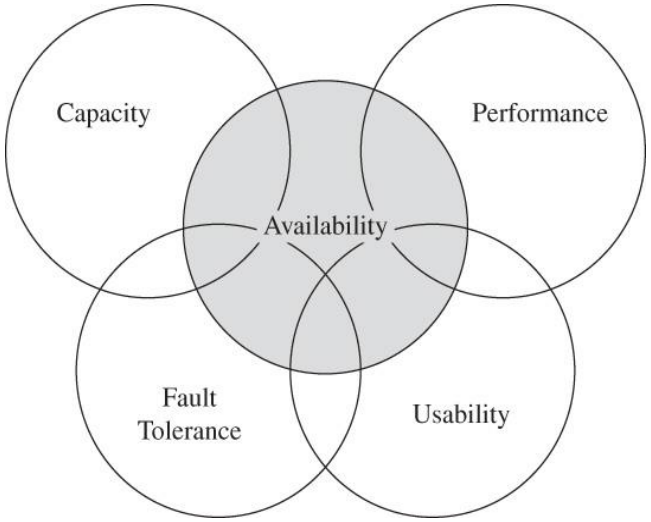
- Hashing
- Error correction/detection
- Version control
- …

CIA Triad: "A"

- Ensure that information and information systems are accessible and usable by authorized users when needed
- Services are <u>not</u> being **denied**
- Key aspects:
  - **System Uptime:** ensure servers, networks, and applications are functioning as they should and when they should
  - **Data Accessibility:** information can be retrieved and processed in a timely manner
  - **Resilience:** ability to withstand and recover from disruptions
  - **Fair Allocation:** ensure the system resources are distribute fairly → prevent starvation

✅ **Examples of availability measures:**

- Redundancy
- Backup
- Load balancing
- …



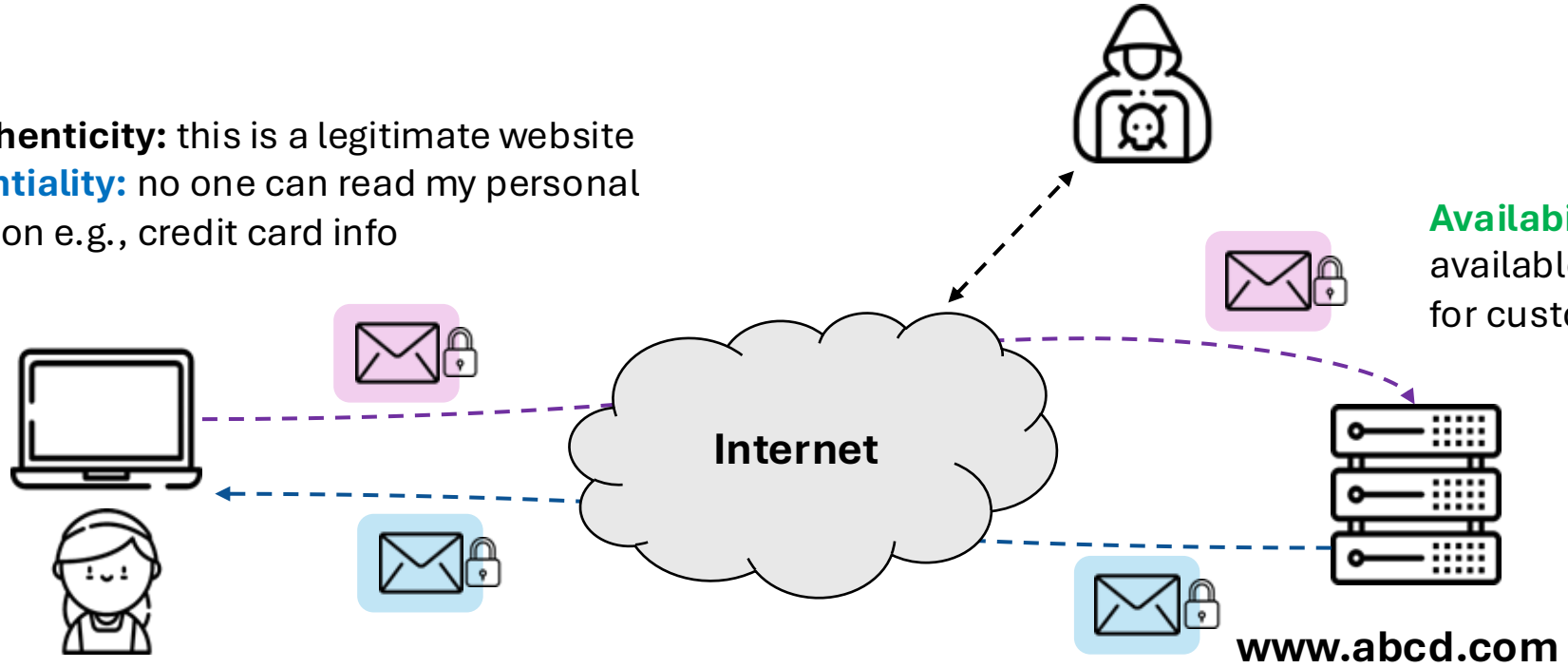
Beyond CIA: Authenticity and Accountability

- ***Authenticity***: ensure that the source of information or an action is genuinely who or what it claims to be
  - Identity **verification**: confirm legitimacy of an entity
  - **Trustworthiness**: establish confidence in the origin of data or actions

- ***Accountability:*** ensure actions within an information system to a specific individual or entity can be traced
  - **Traceability:** link actions to specific users or processes
  - **Non-Repudiation:** prevent user from denying that they performed a particular action
  - **Auditability:** ability to review logs and records to reconstruct events

CIA: Example Scenario

Peer authenticity: this is a legitimate website
Confidentiality: no one can read my personal information e.g., credit card info



Availability: the website is available to provide services for customers 24/7

Data origin authenticity: this message indeed comes from www.abcd.com
Integrity: no one has modified this message

Q&A

"An attacker sends a fake email pretending to be the CEO and instructs an employee to transfer funds to a fraudulent account."

What principle is being violated?

A. Confidentiality

B. Authenticity

C. Availability

D. Integrity

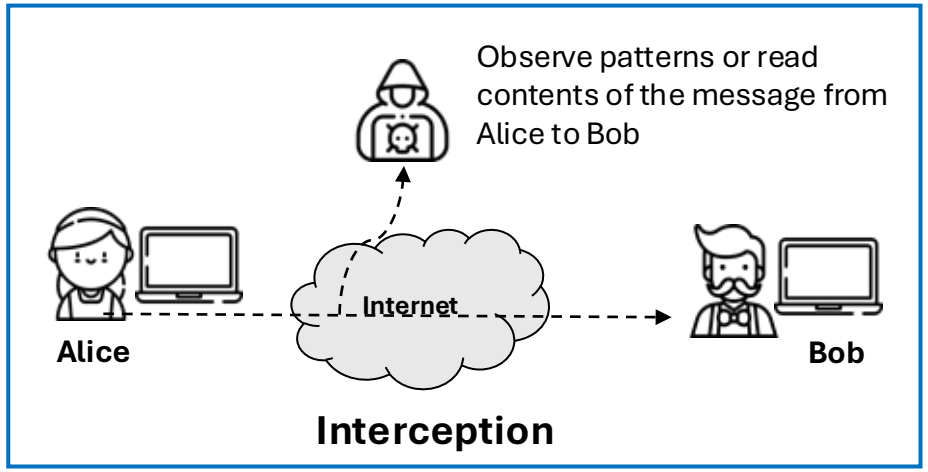
Today's Topics

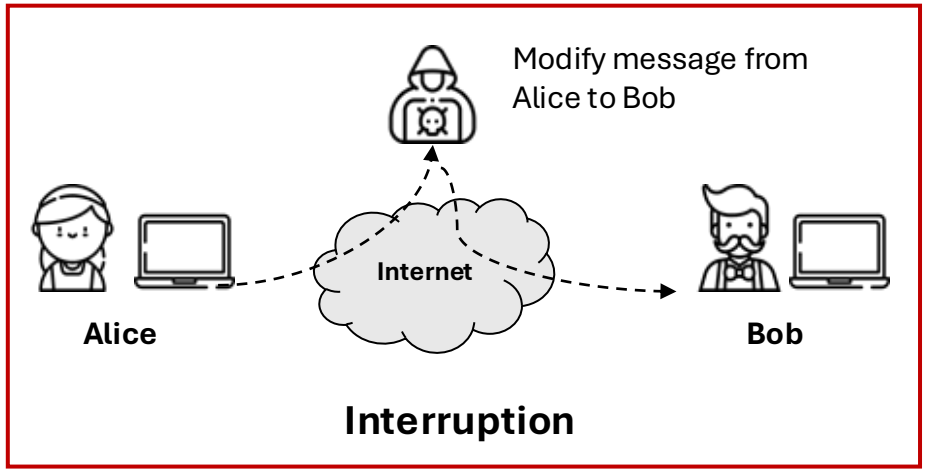
- Cybersecurity trends
- Security definition and terminologies
- Computer security and the CIA triad
- **Security attacks**
- Security controls
- Social engineering

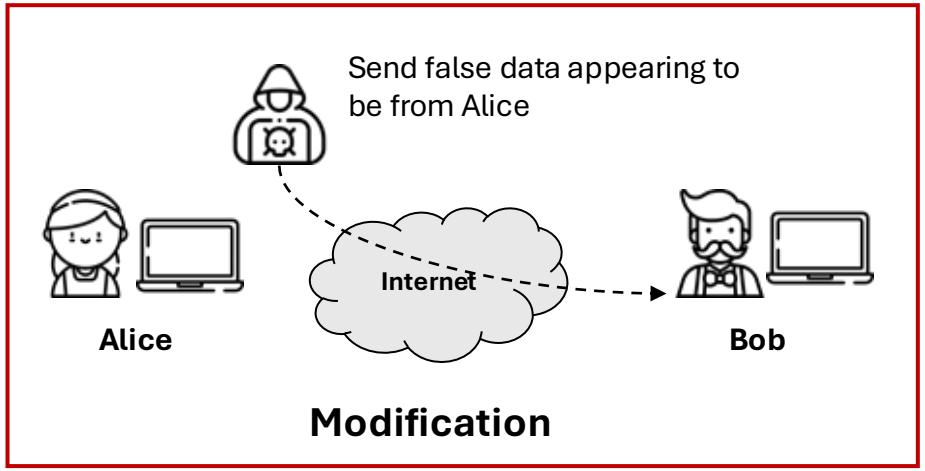
Security Attacks: Types

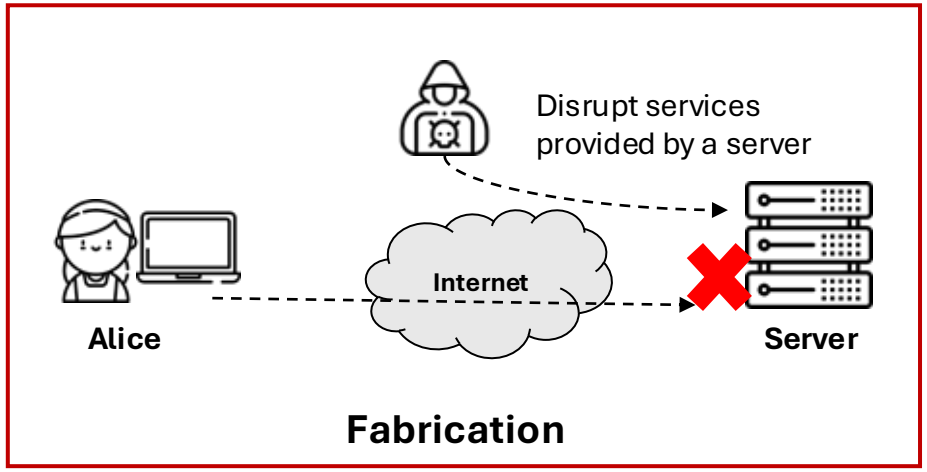
Passive Attack

Active Attack



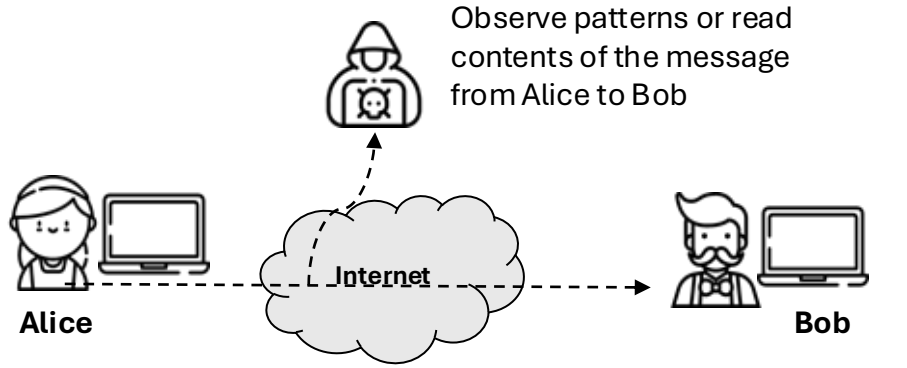


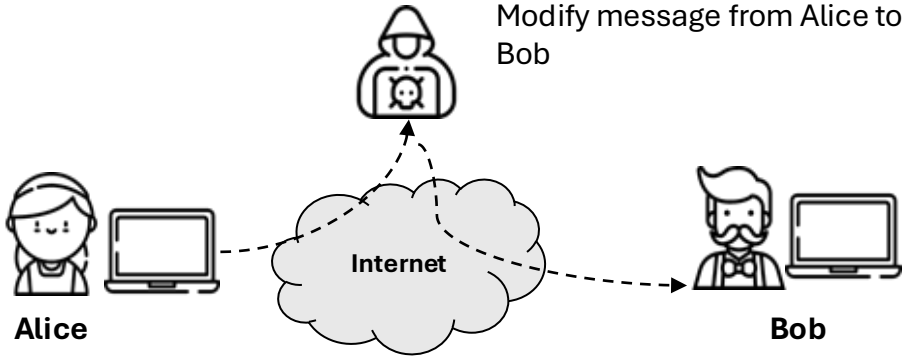




Security Attacks

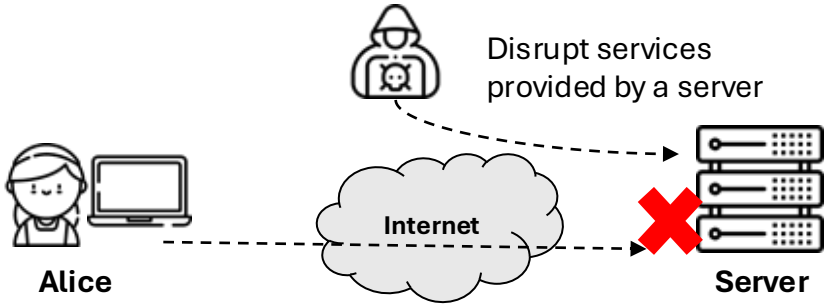
- **Interception:** attack on ***confidentiality***
  - Unauthorized access to resource or information
  - Eavesdropping: monitor communication to steal information, e.g., using packet sniffer
  - Illicit copying of files or program
- **Modification:** attack on ***integrity***
  - Resource is altered or tampered by unauthorized entity
  - Stop the flow of the message, modify it, and release it again



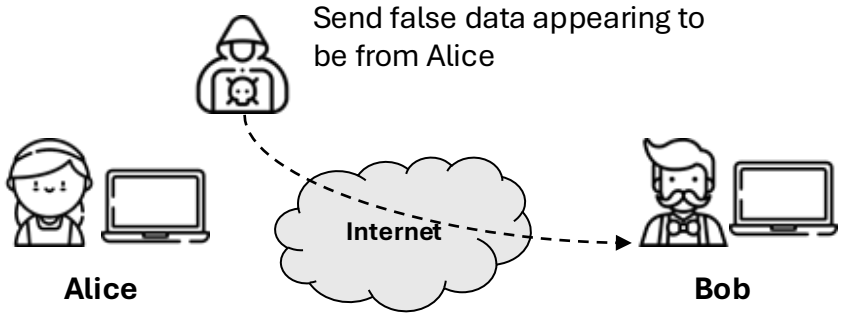


Security Attacks

- **Interruption:** attack on **availability** of system or data
  - Make the asset becomes <u>unavailable</u> or <u>unusable</u>
  - Destroy hardware (cutting fiber) or delete software
  - Corrupt packets in transit/jamming signals
  - ***Denial of service (DoS):*** overwhelm the server by using up its resources



- **Fabrication:** attack on **authenticity**
  - <u>False</u> data or activity are added or performed, and cannot be distinguished from real ones
  - Unauthorized assumption of other's identity
  - Generate and distribute objects under this identity



Attacker Types

- **Amateurs:** opportunistic attackers
  - Uses a password he/she found
- **Crackers** (evil doers) or Hackers
  - Enjoy simple challenge of trying to log in, just to see whether it can be done
- **Career criminals** (cybercriminal)
  - Understand the target of computer crime
  - Motivation is financial profit through illegal activities
- **Terrorists** (cyberterrorist)
  - State-supported spies and information warriors
  - Cause fear or significant disruption to critical infrastructure or public services

Today's Topics

- Cybersecurity trends
- Security definition and terminologies
- Computer security and the CIA triad
- Security attacks
- **Security controls**
- Social engineering

Security Controls

Any measure put in place to reduce cybersecurity risks

Can be categorized based on their <u>functions</u>

- **Preventative Controls:** stop an attack before it happens
  - E.g., firewall, anti-malware, encryption, security awareness
- **Detective Controls:** identify an attack or security breach as it occurs or after it has occurred.
  - E.g., intrusion Detection Systems (IDS), CCTV, security audit
- **Corrective Controls:** restore systems or data to their original state after an incident and prevent recurrence.
  - E.g., data backups and recovery plans, disaster recovery plans, vulnerability remediation.

Security Controls

Security controls can also be categorized by how they are implemented

- **Physical control:** stop or block an attack by using something tangible
  - E.g., walls and fences, locks, human guards, sprinklers and other fire extinguishers
- **Technical control:** counter threats with technology (hardware or software)
  - Include passwords, OS, network protocols, firewalls, intrusion detection systems, encryption, network traffic flow regulators
- **Procedural or administrative control:** use a command or agreement that requires or advises people how to act
  - Laws, regulations, policies, procedures, guidelines, copyrights, patents, contracts, agreements

Security Controls

TYPE OF SECURITY CONTROLS	PREVENTATIVE	DETECTIVE	CORRECTIVE
PHYSICAL CONTROLS	> Fences > Gates > Locks	> CCTV > Surveillance Cameras	> Repair Physical damage > Reissue Access cards
TECHNICAL CONTROLS	> Firewalls > IPS > MFA > Antivirus	> IDS > Honeypots	> Vulnerability patching > Reboot a system > Quarantine a virus
ADMINISTRATIVE CONTROLS	> Hiring & termination policies > Separation of duties > Data classification	> Review access rights > Audit logs & unauthorized changes	> Implement a business continuity plan > Have an incident response plan

Source: https://www.infosectrain.com/blog/types-of-security-controls/

Q&A

Which of the following is an example of a *preventive physical* security control?

A. CCTV system

B. Firewall

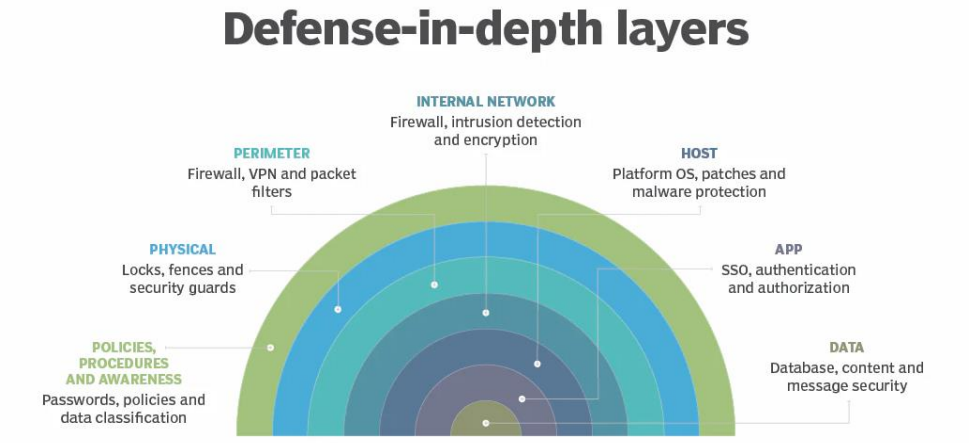
C. Security guard

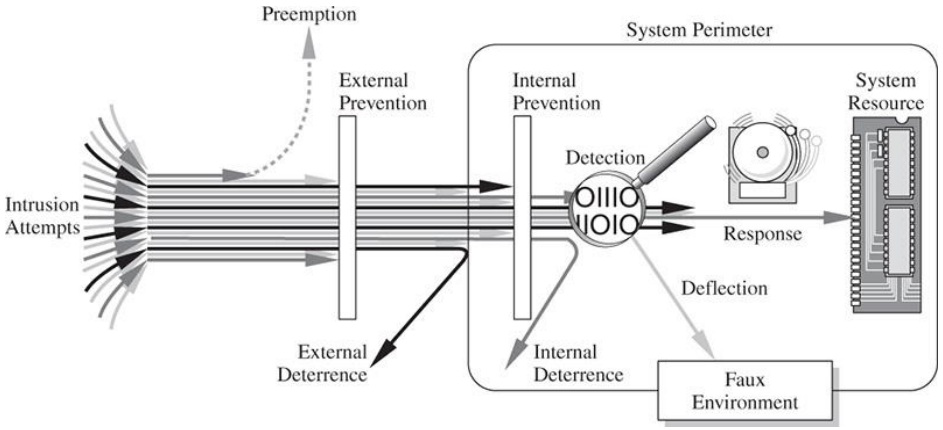
D. Alarm system

Security Controls: Layered Security

- No single control is foolproof
- Effective cybersecurity relies on a "***defense in depth***" strategy, which involves implementing multiple layers of security controls
- **Layered security**
  - If one control fails, another layer is in place to catch the threat
  - Increases the complexity and cost for attackers, making successful breaches less likely

Image: https://www.wiz.io/academy/defense-in-depth





Today's Topics

- Cybersecurity trends
- Security definition and terminologies
- Computer security and the CIA triad
- Security attacks
- Security controls
- **Social engineering**

Social Engineering

*"**Social engineering**" is the psychological manipulation of people into performing actions or divulging confidential information →* ***Hacking the human!***

Key principals

- Authority → CEO, CFO
- Intimidation → Penalty, “your will go to jail”
- Consensus → Bob, also do this
- Scarcity → limited offer, do it now
- Urgency → deadline
- Familiarity → trust

Phishing

- **Phishing**: A technique for attempting to acquire sensitive data, through a fraudulent solicitation in **email** or on a web site
  - Often sent to many recipients
  - *A digital form of <u>social engineering</u>*
- **Spearphishing**: <u>targeted</u> phishing attack aimed at specific individuals or organizations, using personalized information to increase credibility.
- **Whailing: a** type of spear phishing attack specifically targeting <u>high-profile individuals</u> like CEOs or executives.

Phishing

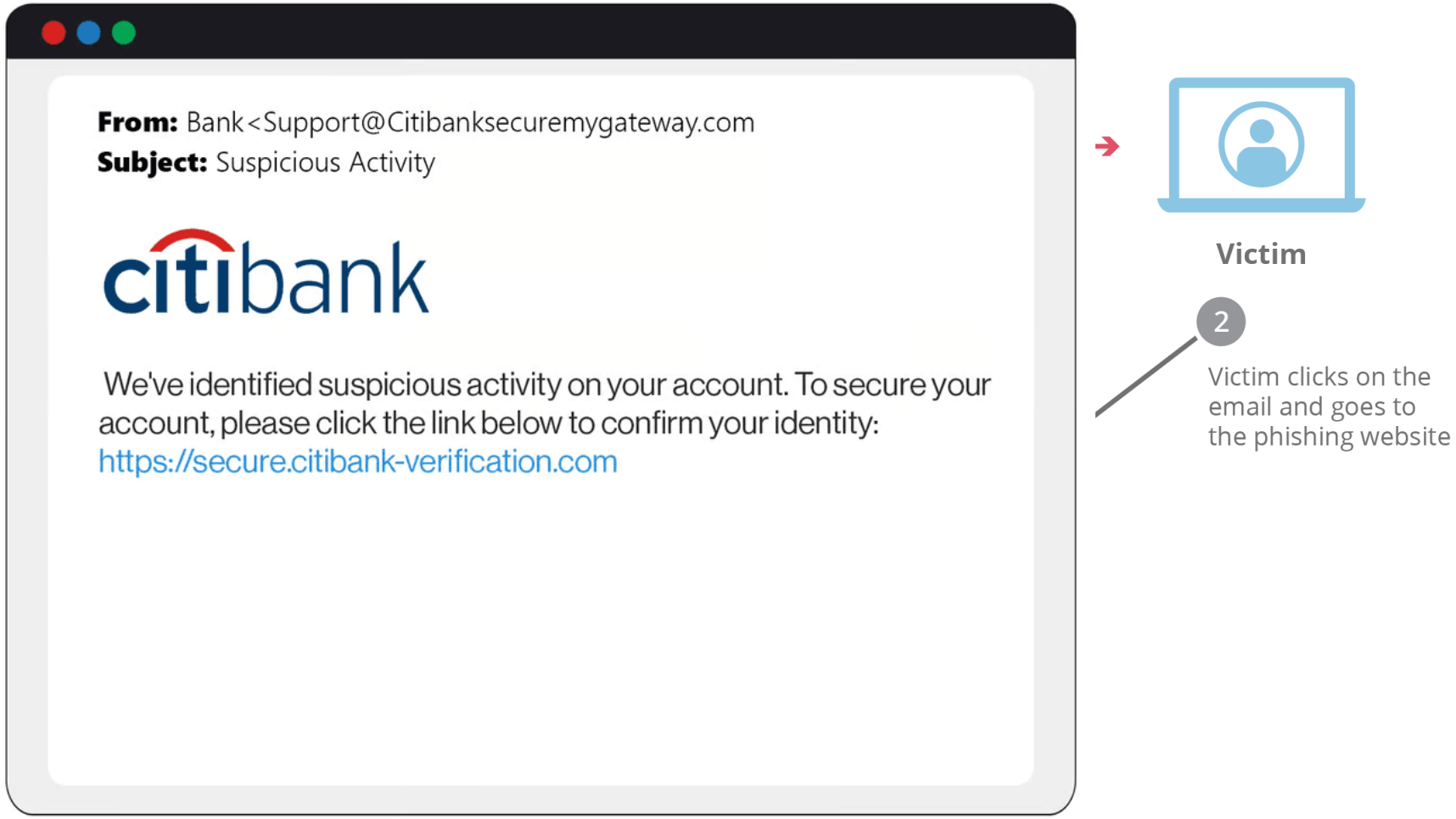


Image: https://www.cloudflare.com/learning/access-management/phishing-attack/

Types of Social Engineering

- **Vishing**: involve fraudulent phone calls or voicemails to obtain sensitive data

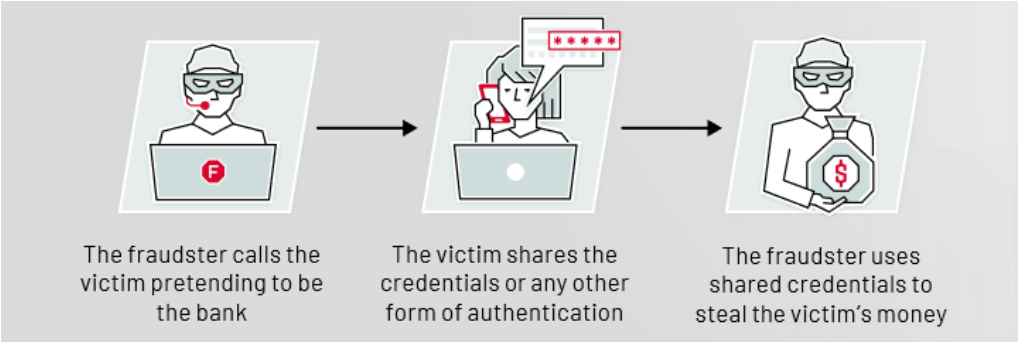
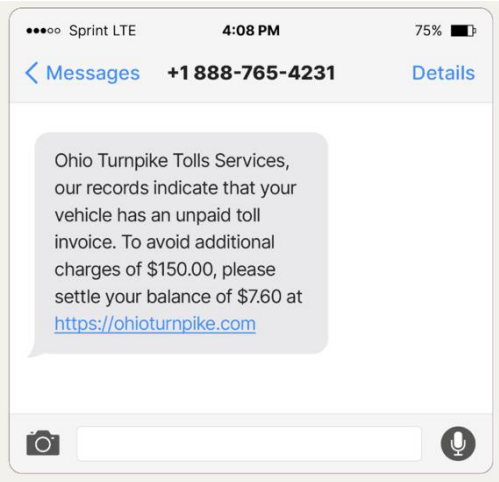


Image: https://www.threatmark.com/on-vishing-attacks-and-how-to-prevent-them/

- **Smishing**: use deceptive text messages (SMS) to trick individuals into revealing personal information or clicking malicious links.



Summary

- Cybersecurity trends: cybersecurity is more critical than ever!
- Security terminologies: asset, vulnerability, threat, attack, control, risk
- CIA triad: **C**onfidentiality, **I**ntegrity, **A**vailability
- Security attacks: Interception, modification, interruption, fabrication
- Security controls: no single control is foolproof. Effective cybersecurity relies on a "defense in depth" strategy
- Social engineering: digital form of social engineering → phishing

มหาวิทยาลัยมหิดล
Mahidol University

ห้ามมิให้นักศึกษาทำซ้ำ ดัดแปลง หรือใช้ประโยชน์จากงานอันมีลิขสิทธิ์ปรากฏอยู่ในระบบการศึกษาอิเล็กทรอนิกส์ (E-Learning) ของมหาวิทยาลัย ไม่ว่าจะทั้งหมดหรือบางส่วนโดยไม่ได้รับอนุญาตจากมหาวิทยาลัย นอกเหนือจากการศึกษาส่วนบุคคล ทั้งนี้ การทำซ้ำ ดัดแปลง หรือเผยแพร่ต่อสาธารณชนซึ่งงานอันมีลิขสิทธิ์ **จะมีโทษปรับตั้งแต่ 20,000 บาท ถึง 200,000 บาท และหากเป็นการกระทำเพื่อการค้า จะมีโทษจำคุกตั้งแต่ 6 เดือน ถึง 10 ปี หรือปรับตั้งแต่ 100,000 บาท ถึง 800,000 บาท หรือทั้งจำทั้งปรับ**

Unless allowed by Mahidol University, the User shall not copy, modify, or exploit in part or in whole of the copyrighted materials on the Platform, other than for your own individual study. The copy, modify or communication to public of the copyrighted materials shall be inflicted with a fine from 20,000 Baht up to 200,000 Baht. If the offence is committed with the commercial purpose, the offender shall be inflicted with imprisonment for a term from 6 months up to 10 years or a fine from 100,000 Baht up to 800,000 Baht or both imprisonment and fine.